# User permissions and improvement register

One reference for the six existing roles, Engineer submission, review decisions and role-specific follow-up.

**Scope: improve what is already developed.**
No additional product modules are included.

**Engineer > QA Engineer > Team Lead > Client (when required) > Closed**

This document separates permitted actions, prohibited actions, confirmed repairs and remaining verification gaps. AI Analysis supports review and never grants an engineering approval.

The Super Admin role is included as the owner’s administration role. It does not substitute operational or technical reviewers.

Use the PDF bookmarks to find a role. Current permission claims are based on server checks and isolated regression journeys; they do not establish production or whole-site engineering acceptance.

Review date: 23 October 2026. Scope: the existing Django survey and inspection application. This guide describes six current roles and the existing review workflow; it is not a plan for additional modules or a production-readiness certificate.

The permission, routing and workspace checks use isolated Django records and synthetic evidence. The category-upload workflow supersedes the earlier Engineer checklist/AI review steps. Actual local vision was also exercised with synthetic images; this establishes integration, not real-site accuracy, physical-device acceptance or production readiness. Current verification evidence is recorded in docs/development/ENGINEER_CATEGORY_QA_WORKFLOW.json.

# How access is decided

An active, unlocked operational account needs an effective project grant. A grant can expire or be revoked; an old primary-project value does not restore a revoked grant. Company boundaries apply to project staff. Admin access is additionally limited to the owning Admin's projects and assigned industry. Multiple project access requires explicit permission. Super Admin has separate platform-administration authority; even global administrative visibility does not grant operational engineering access.

Being able to see a project does not permit every operation on its tasks. Engineer ownership, named QA/Team Lead/Client reviewers, current workflow stage, frozen revision, approved sections and stale-request checks are evaluated again by the server. Hiding a button is not the permission boundary.

| Existing action | Super Admin | Admin / Project Manager | Engineer | QA Engineer | Team Lead | Client |
|---|---|---|---|---|---|---|
| Platform industries, Admin provisioning and global access maintenance | Yes | No | No | No | No | No |
| Create company projects and choose project approval layers | No | Own company and industry | No | No | No | No |
| Create Client organizations or invite Clients | No | Managed company projects | No | No | No | No |
| Create single/bulk site tasks | No | Managed projects | No | No | Assigned projects | No |
| Develop and publish checklist templates | No | Managed template scope | No | No | Technical qualification only | No |
| Upload and organize original evidence | No | No Engineer signature | Own task before submission or after authorized return | No | No | No |
| Submit category photos to QA | No | No | Own task, completed uploads | No | No | No |
| Match photos and review AI suggestions | No | No | No | Named QA at current editable stage | Read completed QA package | No |
| Record derived checklist answers | No | No | No matching or AI acceptance | Named QA; original Engineer source stays frozen | Review only | Shared approved results only |
| Sign QA review | No | No | No | Named QA at current stage | No | No |
| Sign Team Lead review | No | No | No | No | Named Team Lead at current stage | No |

| Existing action | Super Admin | Admin / Project Manager | Engineer | QA Engineer | Team Lead | Client |
|---|---|---|---|---|---|---|
| Sign Client approval | No | No | No | No | No | Named Client after sharing |
| Release generated drawing outputs | No | No | No | Technical package review only | Assigned Team Lead after all release gates | No |
| Open operational tasks/evidence | No | Scoped administrative inspection | Own tasks | Assigned review tasks | Assigned review tasks | Shared current revision only |
| Read published staff work profiles | Administrative account view | Shared-project staff | Shared-project staff | Shared-project staff | Shared-project staff | Eligible published shared-project profiles |

The matrix summarizes the current governed workflow. Retained historical workflows have their original named reviewers and signatures; they are not silently converted into a new route.

Older, unmarked records explicitly using legacy governance retain their original editing rules: a scoped Admin or Team Lead can edit an unfinished legacy checklist, while final records and approved sections remain locked. Once a task uses category submission, its frozen Engineer sources cannot be edited through those older endpoints. A template with Checklist required switched off is not necessarily a legacy-governance record: the AI setting and approval policy are separate.

Historical version-one independent workflows can retain their original named Team Lead validation and Project Manager approval. New governed routes use Engineer, QA Engineer, Team Lead and the optional Client. Never infer a current operational permission from an old stored role label or rewrite a historical signer to fit the new route.

# Engineer

## Purpose and permitted work

- Find assigned tasks and distinguish pending preparation, submitted/review work, returned or rejected corrections, and completed work. The workflow stage and AI processing status are separate.
- Open the assigned site's compact photo-capture workspace and inspect existing task information.
- Select General Info, Civil, Electrical or Tower and upload multiple camera/gallery photos in bounded batches. Preview full images and review saved thumbnails grouped by category.
- Before submission, move photos between categories or remove an incorrect photo from the active intake. Removal retains original bytes and historical source records.
- Retry failed uploads; successful uploads are deduplicated. An unfinished upload envelope must finish or be safely recovered before submission.
- Select Submit to QA after uploads finish. Missing checklist answers do not block this photo hand-off. Necessary task identity, reviewer, access and upload-completion checks remain.
- QA receives the frozen submission immediately. A persistent AI job runs separately; uploading alone does not start it. The Engineer receives a simple confirmation rather than matching or AI verification work.
- The applicable approved checklist controls QA proposals. A missing template is shown to QA as a configuration issue; it does not cause invented checklist requirements or lose the photo submission. Drawing generation retains its existing Checklist required scope.
- Correct a returned task and submit a new retained revision. Prior inputs, evidence, review events and signed revisions remain available.
- Maintain their own professional profile and experience. Published experience is self-reported, not application-certified competence.

## Not permitted

The Engineer cannot match photos to checklist points, confirm/reject AI links, accept AI answers or manually launch/retry the old AI review interfaces. These HTTP restrictions also apply to older records; historical data/signatures remain intact. The Engineer cannot create projects, administer Clients/staff, publish templates, edit another Engineer's task, sign QA/Team Lead/Client decisions, release drawings or change submitted evidence without an authorized return. Matching and missing-checklist resolution belong to QA, while engineering approval remains a separate human decision.

## Current issues and follow-up

| Type | Status | Existing-feature follow-up |
|---|---|---|
| Crowded upload/checklist/submission screens | Replaced by category capture | The Engineer sees task information, category uploads, source previews and Submit to QA. Checklist matching, confidence and AI acceptance controls are absent. Current desktop/mobile checks are recorded in the workflow ledger. |
| Checklist/AI work incorrectly assigned to Engineer | Role responsibility corrected | QA owns matching and derived checklist review. The Engineer task list no longer says Engineer review is next after AI completion; historical internal services remain only for retained data/testing compatibility. |
| Disabled submission buttons had faint/unreadable labels | Fixed; independent browser and visual verification passed | Disabled legacy submission uses dark text (#43556d) on a light background (#e4eaf2), with full opacity. Keep unavailable actions clearly labelled. |
| Old AI endpoints accessible to Engineer | Global HTTP restriction verified | Old analysis enqueue/retry/mapping/acceptance and AI processing mutation routes deny Engineer use, including records without the new intake marker. Existing authenticated document/upload completion operations remain available where authorized. |
| Native processing crash, audit A12 | Open integration issue | An earlier native exit139 has no established root cause. Passing Windows tests do not close the issue; obtain a supported reproduction/backtrace and compatible native dependency evidence. |
| Complete real-site AI accuracy and speed | Not yet accepted | Measure full authorized site batches, incorrect/missed matches, correction effort, retry/restart behavior and actual elapsed processing time. Small synthetic uploads do not prove AI throughput. |
| Phone/network usability | External validation remains | Exercise real Android/iPhone capture, intermittent signal, interrupted batches, offline messages and retry recovery. |
| Concurrent and interrupted uploads | New Engineer capture uses durable upload envelopes | Category capture uses the existing lease/heartbeat/recovery mechanism even when drawings are not required. A live transfer cannot be silently closed; recovery preserves completed originals. Physical phone/network acceptance still remains. |

# QA Engineer

## Purpose and permitted work

- Open tasks where they are the named QA reviewer and still have effective project access.
- Open the category submission immediately, including while AI is pending, processing or failed. Inspect original source photographs, approved checklist requirements and revision history.
- Review General Info, Civil, Electrical and Tower in a compact category/checklist/photo workspace. Required points remain visible without evidence. Not Assigned means no checklist links, not merely no link to the selected point.
- Add, confirm, remove or explicitly reassign individual photo links. Drag-and-drop and click/touch actions use the same revision-bound permission checks. Other valid links remain intact.
- Inspect source photos and QA-visible AI observations/explanations in the viewer. Unsupported suggestions remain unassigned. Preserve original Engineer categories as provenance, even for a valid cross-category link.
- Enter source-backed derived checklist answers and complete the required QA evidence review. These append-only decisions do not rewrite the Engineer's original answers or photo snapshot.
- Change personal checkpoint display order within the existing category only. Display order does not edit the template, source links or engineering decisions.
- Approve the current technical review or return it one step to the Engineer with a reason. A stale token or a change to frozen source inputs blocks a decision.
- In an opted-in AI/drawing package, independently review the exact QA-completed technical package. Drawing release remains separate and still requires the existing workflow gates.
- Inspect approved sections and retained evidence without modifying the Engineer's submission.
- Maintain their own professional profile, qualifications and experience and choose whether to publish it to eligible shared-project colleagues.

## Not permitted

QA cannot create projects or tasks, invite staff/Clients, upload or replace the Engineer's originals, edit approved requirements, use display ordering as template editing, sign Team Lead/Client decisions or release drawing outputs. Assignment, confirmation of a link, reviewed answers and engineering approval are distinct. A photo link does not prove compliance. Approved evidence requires the existing authorized reopening process. QA and Engineer remain distinct actors.

## Current issues and follow-up

| Type | Status | Existing-feature follow-up |
|---|---|---|
| Current-stage and named-reviewer protection | Verified in isolated workflow checks | Keep denials for wrong reviewer, revoked access, stale decisions and changed inputs. |
| QA matching workspace | Current change; see final workflow evidence | Category navigation, scoped per-photo links, Not Assigned, display ordering and responsive saved-data browser checks are tracked against the owner's original acceptance list. |
| Clarification offered before reopened QA review was complete | Reproduced and repaired | After a Team Lead return, the workflow shows Review and complete QA evidence and withholds premature Approve/Clarify. Recomplete the reviewed package before clarifying or approving. Return/reject controls remain available. |
| Raw image context omitted by native model | Structured decoding improved; native retest passed | Native output now includes observed subject and source quotation with a closed set of approved field hints. Unknown remains allowed; this is not a guarantee of whole-site matching accuracy. |
| Technical accuracy of AI findings | Field validation remains | Independently compare real findings and missing/conflicting information with checked site evidence and acceptance criteria. |
| Historical scientific values | Impact review remains | PR13 fixes conversion and reconciliation going forward. Previously stored or signed results were not rewritten; review any suspected historical impact against originals. |
| Native processing stability | Open shared issue, A12 | QA should not treat a successful retry as resolution of an unexplained native crash. |

# Team Lead

## Purpose and permitted work

- Create and assign single or bulk site tasks within effective project access. The task inherits the project's published checklist and three- or four-layer policy.
- Select the Engineer and required named reviewers from permitted project members during the authorized initial task setup. Existing frozen reviewer routes cannot be silently changed.
- Record technical qualification of the applicable checklist/template against the relevant specification and method when required by the workflow.
- Review the completed QA package in the compact category/checkpoint/photo workspace. Its matching controls are read-only for Team Leads. Approve work to the next stage or reject one step to QA with a reason.
- Receive a Client rejection as a Team Lead clarification. Clarify and resubmit to the Client if source inputs remain unchanged, or return one step to QA when further correction is needed.
- Release the exact drawing package only after completed QA evidence review, the assigned QA technical decision, closed task routing and required Client approval. Retained older packages keep their original Engineer-completion prerequisite.
- Choose whether to share the separate checklist critique with the Client through the existing explicit sharing control. Internal photo-model diagnostics remain private.

## Not permitted

The Team Lead cannot create company projects, administer account roles, act as the Engineer or QA signer, bypass required Client approval, edit frozen source inputs to conceal a correction, publish the controlling checklist, or release an unchecked package. Project membership alone does not replace named-reviewer assignment.

## Current issues and follow-up

| Type | Status | Existing-feature follow-up |
|---|---|---|
| One-step rejection and clarification | Verified in isolated three/four-layer journeys | Keep the source revision, decision history and required reason through each return. |
| Readability and completeness of drawings | Engineering/CAD acceptance remains | Use measured units and source-backed geometry. Review actual CAD imports, fonts, Arabic/mixed labels, missing dimensions and customer-approved details. |
| Manufacturer/site geometry | Reference dependency remains | Approved manufacturer blocks and checked site measurements are needed before claiming installed accuracy. Unsupported sheets remain draft/not to scale. |
| Real field/team review experience | External validation remains | Confirm the simplified Engineer hand-off reduces effort without hiding uncertainty or required evidence from reviewers. |

# Client

## Purpose and permitted work

- View only project information and current task revisions that are appropriately shared with their named Client account.
- Inspect submitted source evidence, confirmed links, final answers and any separately shared checklist critique.
- Approve or reject at the Client stage of a four-layer route. A rejection requires a reason and returns to the Team Lead, not directly to the Engineer.
- Open permitted released PDF/DXF outputs. Draft outputs and private internal AI proposal/reasoning/job diagnostics are excluded from the Client projection.
- Read eligible published Engineer/QA/Team Lead/Admin work profiles when both parties retain a shared project. Unpublished profiles and revoked affiliations are not available.
- Maintain their own basic professional profile without changing their account role or grants.

## Not permitted

Clients cannot upload or edit Engineer evidence, accept AI proposals, sign QA/Team Lead decisions, release drawing packages, create or assign tasks, manage accounts/templates, view another named Client's independent deliverable, or access private files through direct media paths. A three-layer project has no Client approval stage.

## Current issues and follow-up

| Type | Status | Existing-feature follow-up |
|---|---|---|
| Internal photo/AI information exposure | PR13 repair verified by Client-privacy regressions | Continue denying pending/rejected proposal details, internal reasoning, provider metadata and job diagnostics. |
| Internal matching information, A13 | Current privacy regressions and browser checks passed | Clients see permitted confirmed evidence and accepted answers, excluding optional unaccepted AI findings. Engineer matching controls are removed; Team Lead matching is read-only. |
| Client sharing and approval usability | Stage-specific checks passed; physical-device acceptance remains | Test the actual customer device and clarify which revision, evidence and outputs are being approved. |

# Admin / Project Manager

## Purpose and permitted work

- Manage company projects within the Super Admin-assigned industry and project ownership/grants. One Admin may own multiple projects; another Admin does not gain access merely by sharing a company.
- Create projects, select their published checklist and choose a three- or four-layer approval route before task creation.
- Create Client organizations, associate them with permitted projects, and invite Engineers, QA Engineers, Team Leads and Clients to managed projects.
- Grant, revoke or expire project memberships within company/industry boundaries. Additional project access is explicit.
- Create single/bulk site tasks and record the basic site information that flows into matching checklist fields.
- Develop checklist drafts, use standard/reused section/checkpoint recommendations, replicate revisions, configure input/evidence rules and publish permitted templates. Used structures and historical task snapshots remain protected.
- Move a checkpoint between real sections/activities in an eligible editable draft while retaining its field identity and evidence rules. Keep every section valid; unpublish an unused published revision before editing, and replicate protected used structures instead of rewriting historical tasks.
- Disable/enable scoped templates. Unpublish an unused template before editing or deletion; deletion also requires removing project-default references. In-use or historically referenced templates remain protected and can be replicated or disabled instead.
- Manage permitted company/client branding and inspect scoped administrative audit history.
- Activate/deactivate or unlock eligible staff where all of the account's affiliations are within their management scope; use scoped revocation when wider affiliations prevent a global account action.

## Not permitted

An Admin cannot change their own industry, create Super Admin/Admin invitations, convert a Client into another role through membership controls, access foreign-company or another Admin's private projects, or substitute an Engineer/QA/Team Lead/Client technical signature. They cannot directly rewrite immutable audit events or approved historical templates/records.

## Current issues and follow-up

| Type | Status | Existing-feature follow-up |
|---|---|---|
| Broad checklist terminology and Engineer overload | Category upload and QA review verified | The Engineer uploads by category. QA sees approved checkpoint requirements in a separate review workspace. The existing draft editor retains stable IDs and published/used-template locks; no historical checklist content was removed. |
| Legacy Project Manager transition | PR13 implementation; actual-target review required if legacy accounts exist | New roles use Admin / Project Manager. Ambiguous industry/company bindings remain deferred; never guess scope or rewrite signed historical reviewers. |
| Older intentional/failed-login locks | Operator review if present | Temporary throttling does not prove why an older real account was locked. Do not bulk-unlock historical accounts. |
| Backup/recovery and hosted operation | Operational acceptance remains | Rehearse a consistent restore of database, originals, outputs and job state; verify scoped HTTPS/PC-worker operation and retention procedures. |

# Super Admin

## Purpose and permitted work

- Maintain platform industries, codes, descriptions and administrative company records.
- Provision industry-specific Admin accounts, bind their industry and assign the owning project administrator through the existing global controls.
- Review administrative project/site identifiers, global account/grant audit history and eligible access-maintenance controls.
- Grant/revoke permitted administrative project access and manage eligible account activation/locks. Administrative invitation controls may provision project staff except Clients; this does not confer a technical signature.
- Perform the existing explicitly confirmed access-maintenance reset, which concerns sessions/invitations/locks rather than deleting survey evidence or approving engineering work.
- Maintain their own basic profile.

## Not permitted

Super Admin does not create company projects, create/invite Clients, use the operational task explorer or engineering exports, edit site answers/evidence, configure engineering reviewers, sign any technical or Client decision, or release drawings. Global administrative visibility is not operational approval authority. The shared-project professional directory is for operational users rather than Super Admin.

## Current issues and follow-up

| Type | Status | Existing-feature follow-up |
|---|---|---|
| Current release reference and older main | Release-selection work remains | Ensure the reviewed feature release is the installation source. An older main branch is not proof that the current security/workflow fixes are installed. |
| Historical global account privileges | Conditional operator review | If an older build granted global flags to company Admins, review the intended account authority explicitly. Current role/login repairs do not prove the history of old stored flags; never bulk-demote legitimate Super Admins. |
| Native crash and reproducible environment | Open integration issue | Identify the native crash cause; maintain supported Windows/Linux dependency and repeatable-test evidence. |
| Audit tamper boundary | Application guards verified; operational custody decision remains | Ordinary ORM edits/deletes are guarded. Privileged raw SQL/host control requires separately accepted retention and tamper-evidence procedures. |
| Production/privacy/device acceptance | Not certified by current tests | Approve staging, backups, token rotation, data retention, incident ownership and actual field-device acceptance before production promotion. |

# Submission and rejection workflow

For the current category-based Engineer submission:

1. Open the assigned task, check its site identity, select General Info/Civil/Electrical/Tower and upload originals. Preview, move or remove incorrect photos before submission. Failed transfers remain visible for retry.
2. Submit to QA after uploads finish. The server validates access, task/reviewer identity and durable upload completion, then freezes the photos/categories and immediately creates the QA hand-off. Checklist completion and Engineer AI acceptance are not prerequisites. Repeated requests reuse that submission/job.
3. The independent worker analyzes actual source images/documents and proposes links to valid IDs from the applicable approved template. Missing, unsupported and conflicting evidence stays visible; there is no invented checklist or automatic engineering acceptance.
4. QA can work before AI completes or after a failure. Select a category and point, inspect sources, use Not Assigned for genuinely zero-link photos, and explicitly assign/confirm/correct links by dragging or click/touch. Original categories and unrelated valid links are preserved.
5. QA records source-backed answers and resolves required review gaps. Completing evidence review freezes the derived QA package; engineering approval/rejection remains a separate existing workflow action. A Team Lead return reopens QA review before clarification.
6. A three-layer task follows Engineer -> QA -> Team Lead -> Closed. A four-layer task follows Engineer -> QA -> Team Lead -> Client -> Closed. Each rejection moves one step back. QA can return to Engineer; a Client rejection goes to Team Lead for clarification or another authorized return.
7. Changed Engineer evidence requires a new retained submission revision. QA-only matching corrections are appended to the reviewed package without rewriting the original Engineer snapshot. Personal point ordering changes display only.
8. Existing drawing generation remains limited to published telecom-survey templates with Checklist required enabled. Other category submissions do not enable drawings merely by reaching QA. Drawings remain draft until the exact package meets technical review and release gates. Authorized Team Lead release and Client output restrictions remain.

Older submission, review and source records are retained. Current Engineer interfaces and HTTP AI restrictions apply without requiring destructive conversion of historical records. Required checklist items can block QA completion/engineering approval even though they no longer block the Engineer's photo hand-off. A missing approved template is a QA configuration problem; the submission and originals remain available.

# Try the current workflow

1. Engineer: open an assigned task, upload photos under the four categories, preview them and use Submit to QA after transfers finish. No checklist matching is required.
2. QA: open that task immediately, even while AI is pending. Choose a category, then a checkpoint or the last Not Assigned entry. Inspect the photo and supplied AI observation.
3. QA: drag a photo onto a checkpoint or use Assign to checklist point. Confirm/correct links separately from reviewing answers and accepting work. Refresh to check persistence. Complete QA evidence review before using the existing approval action.
4. Team Lead: inspect the completed package in the read-only three-pane workspace. Approve or return one step with a reason. Four-layer tasks continue to the named Client; three-layer tasks close after the required reviews.

iSurvix

# Verification evidence and limits

- Final isolated backend run: **894 tests passed in 283.484 seconds**, native process exit0, no failures/errors/skips; application/test source fingerprint was unchanged throughout the run.
- Django checks, migration-drift and pending-migration checks, dependency check, all four retained frontend scripts and 33 JavaScript syntax checks passed. The retained frontend scripts are not browser-layout tests.
- Independent saved-data QA: 47 focused tests and 74 real Edge assertions at 1440px/390px; all 17 original QA acceptance criteria verified. These counts overlap the full suite and are not added together.
- Actual browser scenarios covered category uploads, failed-transfer retry, immediate QA availability, drag/drop and click/touch matching, refresh/order persistence, failed-save rollback, QA completion, Team Lead rejection, Engineer revision and Client return/clarification/closure. No unhandled JavaScript exceptions were recorded.
- An independent AppSec reviewer reproduced and retested six defects: old Engineer AI reads, optional unaccepted Client findings, alternate capture diagnostics, authorized QA reopening locks, stale legacy field-photo projection, and legacy endpoint mutation of frozen category submissions. Its final 59-test security run passed.
- Real local qwen3.5:4b processed 11 synthetic images in isolated jobs, including a final fresh two-image submission against its approved two-point template. Correct advisory links were saved; confirming one did not accept engineering work. Browser-only controlled AI fixtures are identified separately from these real native checks.
- The default installed Ollama service on 11434 currently fails image requests because its native runner is missing. The existing project-dedicated runtime on loopback 11435 successfully processed the real test images. Use the project's startup launcher; no new model was downloaded and no cloud fallback was added. Previously pinned failed jobs are retained rather than silently reset.
- Source snapshots, original image bytes and prior signatures were checked during the isolated journeys. Operational evidence and credentials were compared with the pre-edit recovery checkpoint. No operational survey was approved or reset by these tests.

These results verify the focused saved-data Engineer-to-QA behavior. They do not establish whole-site accuracy, sustained 200/500-photo throughput, engineering compliance, manufacturer geometry, hosted production readiness or physical-device acceptance. Historical native crash A12 remains an investigation item despite the successful local image runs. Full technical receipts, limitations and exact startup commands are recorded in docs/development/ENGINEER_CATEGORY_QA_AUDIT.md.